



Jerry Lin <jerry@museder.com>

[WordPress Plugin Directory] Review in Progress: Museder RestoreOne

WordPress.org Plugin Directory <plugins@wordpress.org>

2025年12月14日凌晨12:04

收件者: Jerry Lin <jerry@museder.com>

! I have reviewed the issues shared in the previous email and unfortunately I don't see what changes you have made to fix the following issue(s).

- Out of Date Libraries
- Allowing direct file access to plugin files

Can you please recheck it and, if necessary, share additional information about how did you fix that? In case you have any doubts don't hesitate to ask.

Once this is sorted out, we can continue with the review.

Thanks!

Review: CHANGESNOTMADE museder-restoreone/artherslin/1Dec25/T2 12Dec25/3.7.1

--

WordPress Plugins Team | plugins@wordpress.org

<https://make.wordpress.org/plugins/>

<https://developer.wordpress.org/plugins/wordpress-org/detailed-plugin-guidelines/>

<https://wordpress.org/plugins/plugin-check/>

On Fri, Dec 5, 2025 at 6:06 PM UTC, Jerry Lin <jerry@museder.com> wrote:

Hi Plugin Review Team, Thank you for your previous feedback on **Museder RestoreOne**. I have gone through your comments and the Plugin Check report and pushed a **new version 2.7.40** of the plugin (uploaded on the "Add Your Plugin" page to replace the original submission). In this version I have:

1. File handling / AlternativeFunctions

- Wrapped all required low-level file functions (fopen, fread, fwrite, fclose, readfile, unlink, chmod, etc.) in clearly documented phpcs:disable/enable blocks.
- Added explanations that these calls are only used for streaming large backup archives where WP_Filesystem is not reliable or efficient.
- Where possible, wp_delete_file() is used instead of unlink().

2. Security: nonce verification and sanitization

- Added or centralized check_ajax_referer() / check_admin_referer() for all AJAX and form handlers.
- Sanitized all \$_POST, \$_GET and \$_FILES inputs using sanitize_text_field(), absint(), sanitize_file_name(), esc_url_raw(), is_uploaded_file(), and array_map() where appropriate.
- Clarified in comments where the plugin uses HMAC-based tokens instead of nonces (for download links), and that those parameters are validated and do not accept arbitrary user input.

3. Direct database queries

- Reviewed all direct SQL queries and added phpcs:disable/enable annotations with explanations.
- All table names are taken from \$wpdb properties or internal whitelists; no user input is interpolated into SQL.

4. REST / AJAX permissions and development helpers

- Ensured that all REST and AJAX callbacks have proper capability checks or permission callbacks.

- Guarded calls to `set_time_limit()` and `ini_set()` with `function_exists()` checks and documented them as needed for long-running backup/restore jobs.

5. Templates and globals

- Added PHPCS annotations to template files explaining that the variables are local view context passed from the plugin's controller and are not exposed as reusable global APIs.
- All plugin globals and hooks are prefixed with `museder_restoreone_`.

After these changes I re-ran **WordPress Plugin Check**. All previously reported *critical* issues (unsafe file I/O, missing nonce checks, unsanitized input, and undocumented SQL) have been addressed. The remaining findings are:

- A few `WordPress.NamingConventions.PrefixAllGlobals.NonPrefixedVariableFound` notices where variables are already prefixed with `museder_restoreone_` and only used inside the plugin's own templates or handlers.
- Some *warning-level* items for `set_time_limit()` / `ini_set()` and direct database queries, which are now documented and guarded as described above.

If you would like me to adjust anything further (for example, refactoring away the remaining globals), I will be happy to make additional changes. Thank you again for your time and for reviewing Museder RestoreOne. Best regards,
Jerry Lin · WordPress.org Plugin Directory <plugins@wordpress.org> 於 2025年12月2日週二 上午2:34寫道：

On Fri, Dec 5, 2025 at 6:01 PM UTC, WordPress.org Plugin Directory <plugins@wordpress.org> wrote:

This is an automated message to confirm that we have received your updated plugin file.

File updated by artherslin, version 2.7.40.

Comment: Hi Plugin Review Team,

[隱藏引用文字]

https://wordpress.org/plugins/files/2025/11/05_18-01-09_museder-restoreone.zip

--

WordPress Plugins Team | plugins@wordpress.org

<https://make.wordpress.org/plugins/>

<https://developer.wordpress.org/plugins/wordpress-org/detailed-plugin-guidelines/>

<https://wordpress.org/plugins/plugin-check/>

On Mon, Dec 1, 2025 at 6:33 PM UTC, WordPress.org Plugin Directory <plugins@wordpress.org> wrote:

[隱藏引用文字]